

RAG-Augmented Multi-Agent LLM Framework for Explainable Software Vulnerability Detection Using CWE Knowledge Bases

Richa Verma (25MCSS02) Advisor: Dr. Akshay Pandey

Finding the right CWE page

Where this fits

We have short Java examples, a pattern checker, and a small book of CWE facts. This note is about search: given some Java, which book page should we show.

Search is not the same as detection. A good search finds the right weakness page. It does not, by itself, decide that the code is unsafe.

The idea we started with

If the model or the template is shown the wrong CWE page, the explanation will be fluent and wrong. So we measured search on its own, before we trusted it inside a full run.

We assumed that the words in the code are not the same as the words on the CWE page. A search that only shares exact words will miss some real matches. A search that only uses a neural model may miss an obvious id that the pattern checker already found.

Why we chose this way

We compared three setups rather than picking one. Word match is the simple baseline. MiniLM is a small meaning model that can run locally. The mix adds the pattern checker's hinted id and one hop along parent and child links.

The questions are the 18 practice items whose correct CWE we already know. We did not use Juliet here. A search score on our own questions only tells us whether the book can be retrieved. It does not tell us whether bugs are found.

We record which model actually ran. If MiniLM cannot be downloaded, the system falls back to word match. Hiding that fallback would make a later score look like a neural result when it was not.

What we actually did

We wrote 18 labeled questions from the practice files. Each question has a known right CWE. We then ask three searches to rank the book.

Word match (TF-IDF) looks for the same words in the question and on the page. It does not know that "query built by joining strings" means SQL injection unless those words overlap.

Meaning match uses a small model called MiniLM. It can rank a page higher when the idea is similar, even if the words are not identical. If that model cannot be loaded, we fall back to word match and we write that down.

The mix uses both rankings, plus two extra hints: the CWE id suggested by the pattern checker, and the parent or child pages of a hit. The mix is called hybrid search.

R@1 means the right page was the first result. MiniLM was first on 17 of the 18 questions, which is 0.944. Word match was first on about 14 of 18, which is 0.778. On this small set the

mix matched MiniLM. It did not beat it.

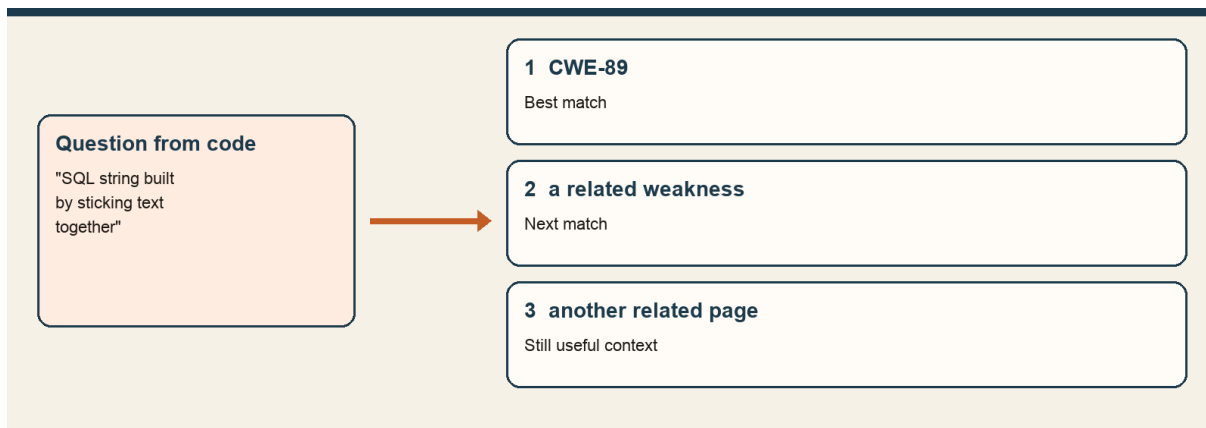
A concrete example

The question is the idea "a SQL string is built by sticking text together". Word match may miss this if the CWE page says "injection" and the question says "sticking text". The meaning model can still rank CWE-89 first.

If the pattern checker has already hinted CWE-89, the mix gives that hint a vote as well. Related pages, such as a child of CWE-89, can appear just below the best hit. They are context, not a second decision.

If MiniLM cannot be downloaded, the same question is answered by word match only, and the result file says so. We do not quietly pretend the meaning model ran.

Picture



A short question from the code is ranked against the book. The first hit is the page we would show.

The numbers

Search	Right page first (R@1)	Questions
Word match (TF-IDF)	0.778	18
Meaning match (MiniLM)	0.944	18
Mix of both	0.944	18

R@1 is not a detection score. It only says whether the correct CWE page was ranked first. These 18 questions come from our own files.

What we concluded, and why

We can now retrieve a page. We still do not have one fixed shape for the written answer, so two runs could look different.

The next piece of work is a single answer form: decision, CWE, lines, cause, explanation, and fix. The conclusion here is that meaning match finds the right page more often than word match on these 18 questions, and the mix did not improve that first-hit rate further.

What we are not saying

This is not a public benchmark. A high R@1 here does not mean the tool finds bugs in Juliet or

in real projects.